

1. m_1 will not be encrypted. Use same key in m_2 and m_3 , Eve can get C_2 and C_3 , where $C_i = m_i \oplus k_i/2$. Thus Eve is able to $C_3 \oplus C_2$ which will end up with $m_2 \oplus m_3$, which is considered an attack, because of limited language format, possible to decode it in a reasonable time, eg am, Hello, Jonathan, I; able to find the true message.

CE/CZ4055: CPS Security Tutorial 2

- (1)(a) An Encryption scheme comprises of a set of deterministic algorithms $(\mathcal{E}, \mathcal{D})$ and is defined over the message space $\mathcal{M}$, ciphertext space $\mathcal{C}$ and key space $\mathcal{K}$ as follows:

Encryption: $c = \mathcal{E}(k, m) = k \oplus m \mid c \in \mathcal{C}, k \in \mathcal{K}, m \in \mathcal{M}$

Decryption: $m = \mathcal{D}(k, m) = c \oplus k \mid c \in \mathcal{C}, k \in \mathcal{K}, m \in \mathcal{M}$

Alice wants to send messages in English to Bob, but decides to encrypt the messages using the above mentioned encryption scheme. She encrypts n messages $(m_1, m_2, \dots, m_n)$ with $n/2$ keys $(k_1, k_2, \dots, k_{n/2-1})$ already shared with Bob such that k_i is used to encrypt messages (m_{2*i}, m_{2*i+1}) for $i \in \{1, 2, \dots, n\}$. Eve passively eavesdrops on this communication from Alice to Bob and could only retrieve the encrypted ciphertexts sent by Alice. Can Eve retrieve the messages from the encrypted ciphertexts. If the encryption scheme is secure, please provide formal proof of security for the same. If not, please provide a possible attack that can be mounted by Eve to retrieve the encrypted messages.

- (b) Alice and Bob use secure One Time Pad ciphers for their two way communication. They use same set of n keys $(k_1, k_2, \dots, k_n)$ to sign a set of n messages $(m_1, m_2, \dots, m_n)$. Is their communication secure?

2. Alice sends $m_1 \oplus k_1 = c_1$, Bob sends $m_1' \oplus k_1 = c_1'$. Eve can capture c_1 and c_1' thus can get $m_1 \oplus m_1'$, which is a successful attack, as explained in qns 1.

- (c) The One Time Pad cipher is a perfectly secure cipher. But, One Time Pads are rarely used for practical applications. Please discuss the reasons for the same.

As the key needs to be as long as the message for XOR bitwise, that's why usually stream cipher, only need to have seed to generate Pseudo RNG (PRNG) which is derived from key

- (2) Assume a Pseudo Random Number Generator (PRNG) $G : K \leftarrow \{0, 1\}^* \mid K \in \{0, 1\}^n$ outputs a random sequence when given an input seed K of length n such that $\text{XOR}(G(K)) = 1$. Is the Pseudo Random Number Generator really pseudo random? If not, state reasons why it is not.

PRNG as a whole is not supposed to be predictable, its properties should not be able to be predicted. thus it's not a good PRNG. To fully check for PRNG, a monobit test should be roughly 50% 0 or 1. The 3 bit check, check every 3 bit, the 8 different combinations should have similar proportions

- (3) (The 802.11b insecure MAC). Consider the following MAC (a variant of this was used for WiFi encryption in 802.11b WEP). Let F be a PRF defined as $F : \{0, 1\}^{128} \times \{0, 1\}^{128} \rightarrow \{0, 1\}^{32}$. Let CRC32 be a simple and popular error-detecting code meant to detect random errors; $\text{CRC32}(m)$ takes inputs $m \in \{0, 1\}^*$ and always outputs a 32-bit string. For this exercise, the only fact you need to know is that $\text{CRC32}(m_1) \oplus \text{CRC32}(m_2) = \text{CRC32}(m_1 \oplus m_2)$. Define the

following MAC system (*Sign*, *Verify*) as:

$Sign(k, m) = r \leftarrow \{0, 1\}^{128}, t = F(k, r) \oplus CRC32(m)$, Output: (r, t)

$Verify(k, m, (r, t)) = \{\text{accept if } t = F(k, r) \oplus CRC32(m) \text{ or reject otherwise}\}$

Show that this MAC system is insecure.

$t1 = F(k, r1) \oplus CRC32(m1)$

$t2 = F(k, r2) \oplus CRC32(m2)$

Alice sends $(t1, r1, m1) + (t2, r2, m2)$ to bob

Eve sees $t1 + t2 + r1 + r2 + m1 + m2$

$t1 \oplus t2 = F(k, r1) \oplus CRC32(m1) \oplus F(k, r2) \oplus CRC32(m2)$

$= F(k, r3)$ (Can find prove online) $\oplus CRC32(m1 \oplus m2)$, where $F(k, r1) \oplus F(k, r2) = F(k, r3)$

$= F(k, r3) \oplus CRC32(m3)$ which can be equal to $t3$, its considered attack as MAC will see this as valid message which can be used for DDOS attack by flooding the requests.